

KAPASA MAKSA UNIVERSITY

DEPARTMENT OF INFORMATION AND COMMUNICATION TECHNOLOGY

SECURITY AND RISK MANAGEMENT PRACTICES

CYS 410

RISK MANAGEMENT

BY MULENGA M.M

RISK MANAGEMENT

- The process of taking actions to assess risks and avoid or reduce risk to acceptable levels.

- Find the risk → Understand the risk → Assess the risk → Treat the risk → Monitor the risk.

RISK MANAGEMENT, SECURITY AUDITING AND NMAP

Risk Management

- Organisations depend on information, computers, networks, people and physical facilities.
- These resources can be damaged, lost, misused or accessed without permission.
- Such events can interrupt operations and cause financial, legal or reputational consequences.
- **Risk management** provides a structured way of dealing with these possibilities.
- The lecturer should emphasise that security is not simply about installing software.
- It is about identifying what can go wrong and deciding how the organisation should respond


1
Identify
Find the assets, threats and vulnerabilities.
2
Assess
Determine the likelihood and impact of each risk.
3
Treat
Reduce, avoid, transfer or accept the risk.
4
Monitor
Check the effectiveness of controls and review changes.
5
Report
Document findings and recommend improvements.
RISK MANAGEMENT
Identify • Assess • Treat
Monitor

Risk Management in an Organisation

- Risk management supports management in making informed security decisions.
- It begins by identifying important organisational assets.
- The organisation then considers what could threaten those assets.
- Weaknesses that could allow threats to cause harm are identified.
- The likelihood and impact of possible incidents are assessed.
- Appropriate controls are selected to reduce significant risks.
- Risks are continuously monitored because organisational systems and threats change.

RISK

The probability of suffering harm or loss. It refers to an action, event or a natural occurrence that could cause an undesirable outcome, resulting in a negative impact or consequence.

Steps in Risk Management

Risk management is a continuous process. It follows a logical sequence to help an organisation identify, reduce and monitor risks.

1 Risk Assessment



Identify and analyse the risks that could affect the organisation.

- Identify assets (what needs protection).
- Identify threats (what could cause harm).
- Identify vulnerabilities (what could be exploited).
- Assess likeilhood (how probable).
- Assess impact (how serious).
- Determine the level of risk.

2 Risk Mitigation



Take action to reduce the level of risk to an acceptable level.

- Select appropriate controls (preventive, detective or corrective).
- Implement security measures (technical, administrative or physical).
- Reduce likeilhood or impact where possible.
- Avoid, transfer or accept remaining risks when necessary.

3 Evaluation



Check whether the controls are working and risks are under control.

- Monitor and measure effectiveness of controls.
- Review changes in threats, vulnerabilities and the environment.
- Reassess risk levels.
- Update the risk register.
- Improve controls where needed.

Assess → Mitigate → Evaluate → Safer Organisation

RISK ASSESSMENT

- The process of identifying threats to information or information systems, determining the likelihood of occurrence of the threat, and identifying system vulnerabilities that could be exploited by the threat.
- Risk assessment is the first phase in the risk management process.

THE BASIC RISK MANAGEMENT CHAIN

- ❑ Start with the **asset** that requires protection.
- ❑ Ask what **threat** could affect the asset.
- ❑ Determine whether a **vulnerability** exists.
- ❑ Assess the likelihood that the threat could exploit the vulnerability.
- ❑ Consider the potential impact on the organisation.
- ❑ Determine the risk and select appropriate controls.
- ❑ Continue monitoring after controls are implemented.

Asset → Threat → Vulnerability → Likelihood → Impact → Risk → Control.

WHY WE CARRY OUT SECURITY AUDITS

- Risk management requires reliable information about the current security situation.
- A **security audit** provides a systematic examination of security arrangements.
- The auditor compares actual practices with policies, requirements and expected controls.
- Technical systems may be examined alongside documents and procedures.
- The objective is not simply to find faults.
- The objective is to provide evidence that helps management understand and manage security risks.
- Audit findings therefore contribute directly to the risk-management process.

ROLE OF THE CYBER SECURITY PROFESSIONAL

- A security professional helps an organisation understand and manage security risks.
- They identify important information and technology assets.
- They assess threats and vulnerabilities affecting those assets.
- They evaluate existing security controls.
- They participate in security audits and risk assessments.
- They document findings and recommend appropriate improvements.
- They may support incident response, security awareness and policy development.
- Their work should support organisational objectives rather than simply create technical restrictions.

BEFORE STARTING AN AUDIT

- An auditor should not immediately begin scanning computers.
- First determine **what is being assessed and why**.
- Define the audit objectives and scope.
- Identify the systems, departments or facilities included.
- Obtain appropriate authorisation.
- Identify applicable organisational policies and requirements.
- Determine what evidence will be required.
- Establish the boundaries of technical testing.

UNDERSTANDING THE AUDIT SCOPE

- THE **SCOPE** DEFINES THE BOUNDARIES OF THE ASSESSMENT.
- FOR EXAMPLE, MANAGEMENT MAY AUTHORISE AN AUDIT OF THE UNIVERSITY COMPUTER LABORATORY.
- THE SCOPE MAY INCLUDE LABORATORY COMPUTERS AND NETWORK EQUIPMENT.
- IT MAY EXCLUDE SERVERS BELONGING TO ANOTHER DEPARTMENT.
- THIS DISTINCTION IS IMPORTANT BECAUSE TECHNICAL TESTING WITHOUT PERMISSION CAN CREATE SECURITY AND LEGAL PROBLEMS.
- A WRITTEN SCOPE HELPS THE AUDITOR REMAIN FOCUSED.

IDENTIFYING ORGANISATIONAL ASSETS

- Begin the practical assessment by creating an asset list.
- Record computers, servers, network devices and important applications.
- Record important information stored or processed by the systems.
- Identify the owner or responsible department.
- Determine which assets are critical to operations.
- Consider what would happen if an asset became unavailable.
- Asset identification provides the foundation for subsequent risk assessment.

UNDERSTANDING THE NETWORK

- Technical risk assessment requires an understanding of how devices communicate.
- A **network** connects computers and other devices so they can exchange information.
- A **host** is a network-connected device such as a computer or server.
- Each host may have an **IP address**, which identifies it on the network.
- Understanding these components helps the auditor identify technical assets.
- This information can later support authorised network assessment using tools such as Nmap.

Using Windows to Gather Basic Evidence

- Open Command Prompt.
- Run:

  hostname
- This displays the computer's network name.
- Run:

  whoami
- This displays the currently logged-in Windows account.
- Run:

  ipconfig
- This displays network configuration information.
- Record the results as part of the audit evidence

READING **IPCONFIG** RESULTS

- The **IPv4 address** identifies the computer within the network.
- The **subnet mask** helps determine which addresses belong to the local network.
- The **default gateway** is normally the router or network device used to reach other networks.
- For example, a computer may have:
  192.168.8.103
- Its gateway might be:
  192.168.8.1
- This information helps establish the network environment before conducting an authorised assessment.

INTRODUCING NMAP

- **Nmap (Network Mapper)** is used for network discovery and security auditing.
- NMAP 7.99 for windows
- It can help identify responding hosts and examine network ports.
- It can also attempt to identify services running on those ports.
- In risk management, Nmap provides **technical evidence**.
- The evidence must then be interpreted in relation to assets, threats and vulnerabilities.
- Nmap itself does not determine the final risk.

INSTALLING NMAP ON WINDOWS

- Open a web browser and visit the official Nmap website.
- Select the Windows download.
- Download the official installer.
- Run the installer after the download finishes.
- Accept the licence agreement.
- Keep the recommended installation options.
- Allow **Npcap** to be installed.
- Npcap enables Windows applications such as Nmap to interact with network traffic.
- Complete the installation.
- Official Nmap website

Confirming the Installation

- Open Command Prompt after installation.
- Type:

nmap --version

- Press **Enter**.
- Nmap should display its version and installation information.
- This confirms that the command is available.
- At this stage, installation is complete.
- The next task is to use Nmap to gather authorised technical evidence.

USE OF LOCAL HOST

- Begin with the computer being used for the practical.
- This avoids immediately scanning other devices.
- Use:

  nmap 127.0.0.1
- **127.0.0.1 is the loopback address**, which refers back to the same computer.
- Nmap examines selected TCP ports on the computer.
- Record the results.
- The purpose is to learn how technical findings can become part of a risk assessment.

MOVING FROM TECHNICAL RESULTS TO RISK

- Suppose Nmap reports that several ports are open.
- Do not immediately label them as vulnerabilities.
- First identify what services are operating through those ports.
- Determine whether those services are required.
- Examine their configuration and access restrictions.
- Determine what threats could take advantage of weaknesses.
- Finally, assess likelihood and impact.
- This is where technical scanning becomes risk management.

Why use it in an IT audit?

It is useful for a **safe first audit** because examines your own machine without scanning another device.

For example:

nmap -sV 127.0.0.1

This asks Nmap to:

- ❑ scan the local computer;
- ❑ identify open ports;
- ❑ identify services;
- ❑ attempt to determine service versions.

127.0.0.1 is the loopback address used to test and audit services running on the local computer.

END